



API Security Testing Lab

Objective

This report documents the findings, methodologies, and outcomes from the API Security Testing Lab. The lab focuses on identifying OWASP API Top 10 vulnerabilities using industry-standard tools in a controlled DVWA (Damn Vulnerable Web Application) environment

Target Environment

Target Application: DVWA (Damn Vulnerable Web Application)

Target Endpoint: /DVWA/vulnerabilities/api/

Tools: BurpSuite, Postman

Vulnerability Test Log

The following table records all test cases performed against the DVWA API, mapped to the OWASP API Top 10 framework.

Test ID	Vulnerability	Severity	Target Endpoint
001	Broken Object Level Authorization	Critical	/api/user/{id}
002	Broken Object Property Level Authorization	High	/api/v1/user

API Test Summary

The API security testing lab identified two critical vulnerabilities in the DVWA API: a BOLA flaw at /api/user/{id} enabling unauthorized data access, and an Indirect Data Exposure risk at /api/v1/user. Using Burp Suite and Postman, testers confirmed exploitable authorization gaps and injection vectors. Immediate remediation is recommended to prevent unauthorized access and data exposure.

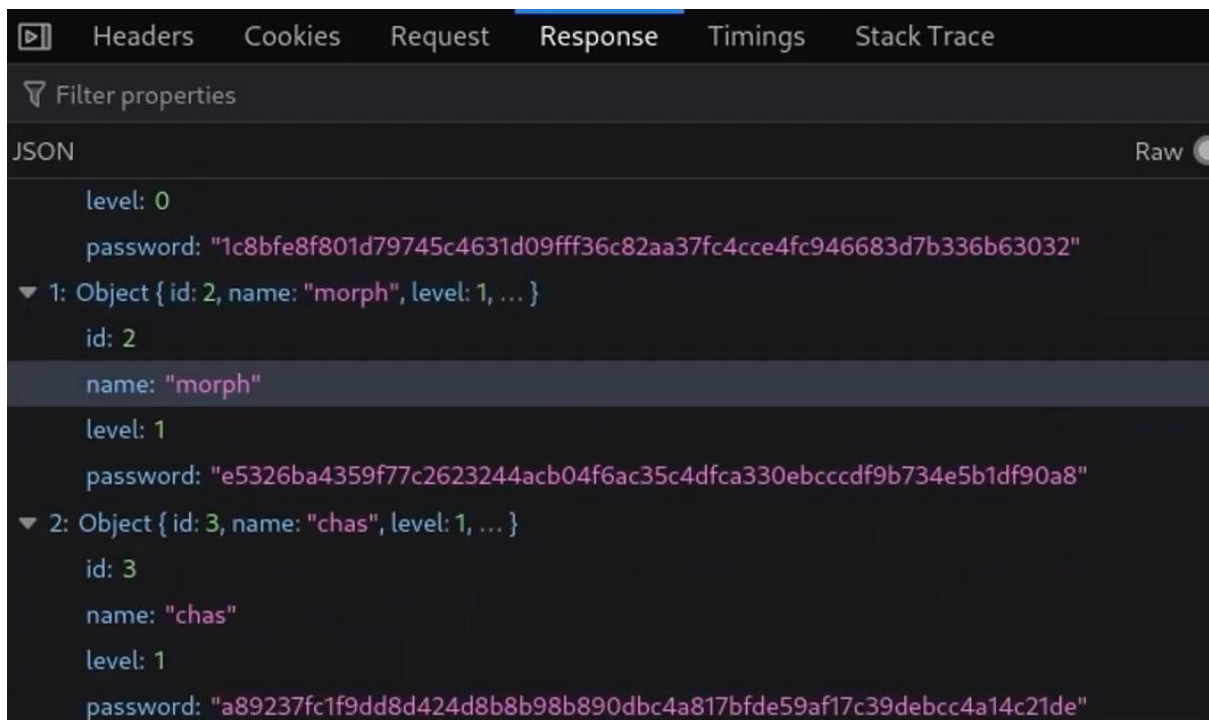


Fig 1: Unauthorized data access

Recommendations

- Implement strict object-level authorization checks on all API endpoints to prevent BOLA exploitation
- Enforce token expiration, rotation, and signature validation to prevent token manipulation attacks
- All legacy API versions (v1) that are no longer in active use must be immediately disabled at the server level.
- Conduct regular automated API scanning with sqlmap and manual verification via Burp Suite
- Organizations must maintain a formal API inventory documenting all active, deprecated, and retired versions.